Name: Amanuel Getachew
ID: CTC_3219_26

Contents

Introduction 2
Reconnaissance 2
    nmap 2
Vulnerability Scanning 3
Exploitation 4
    Metasploit 4
Extras 5
    Diffie-Hellman Key Exchange 5
    Quantum Computers in Cryptography 6

Introduction

After finishing the camp phase of the program I have been working on developing my skill mainly focusing on penetration testing. Penetration testing also known as pentesting means attacking a computer system with consent to find vulnerabilities. pentesting includes steps from information gathering to compromising the system and reporting our findings.

Reconnaissance

The first stage of pentesting is reconnaissance which is simply collecting information about a system to find any weakness that could be used to compromise it. The next part will talk about nmap which is one of the most important tools we use to gather information.

nmap

nmap is a tool used for port scanning. A port is a logical identifier used to differentiate different programs running on a computer to allow a network traffic reach the correct program.

Depending on the level of information we want to collect, there are different flags that can be used with nmap. If what we want is quickly scan only the most common ports we can run the command `nmap -F [target]`. The `-F` flag stands for fast and will scan only the most common 100 ports on the target while `[target]` is a place holder for an IP address. If we want to scan a specified number of ports, for example the top 2000 ports we can run `nmap --top-ports 2000 [target]`

The scans above can only give us information on a limited number of ports. To scan all ports use `nmap -p- [target]` which will scan all ports from 1 to 65535. we can also specify a range of ports to scan by using the `-p` flag. For example `nmap -p 12-2000 [target]` will scan ports from 12 to 2000.

All the commands we have seen will tell us if the port we scanned is open or not but we can also get other useful information by using nmap. As an example running `nmap -sV [target]` will try to find what software and its version is running behind the ports. The `-sC` flag can be used to get extra information outside of version number. The `-O` flag can be used for OS detection. Using the `-A` flag will perform aggressive scan by combining `-sV`, `-sC -O` and `--traceroute` flags together.

Although the commands in the previous section can give comprehensive information it is easy to detect a port is being scanned, resulting in being blocked by a firewall. If we get no result after an nmap scan we can run a SYN can to make sure we are not being blocked.

In a normal TCP scan a three way handshake will be performed as shown in Figure 1. The first will be a synchronization request which we will call SYN. After that the receiver will respond by sending an acknowledgment which is SYN-ACK for short and lastly the first device will send an acknowledgment which we will call ACK.

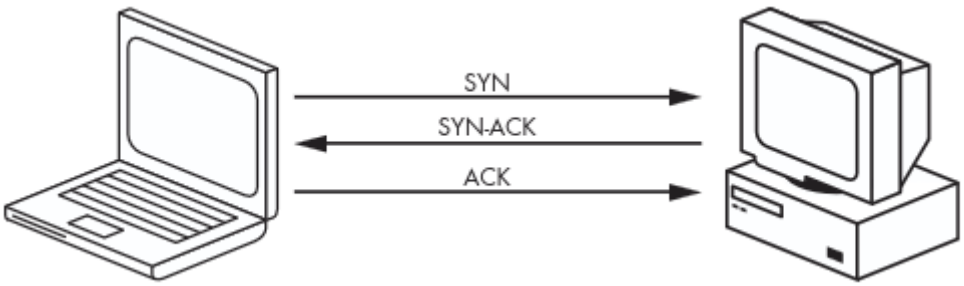


Figure 1: A three way handshake

A three way handshake is necessary to establish a TCP connection but we can skip the last ACK when using nmap to minimize the chance of us being detected. `nmap -sS [target]` will be the command we run in that case (for a SYN scan).

Vulnerability Scanning

Some of the information we can gather using nmap could give us a hint on what to do next. For example if we run the command `nmap -A [target]` and find out the specific name and version of the software being used on a specific port we can search for known vulnerabilities for that system. For example if we find out Apache 2.4.49 is being used as an HTTP server, we can then search for known vulnerabilities for that specific Apache version. The result of the search would look like Figure 2 on https://www.cve.org/

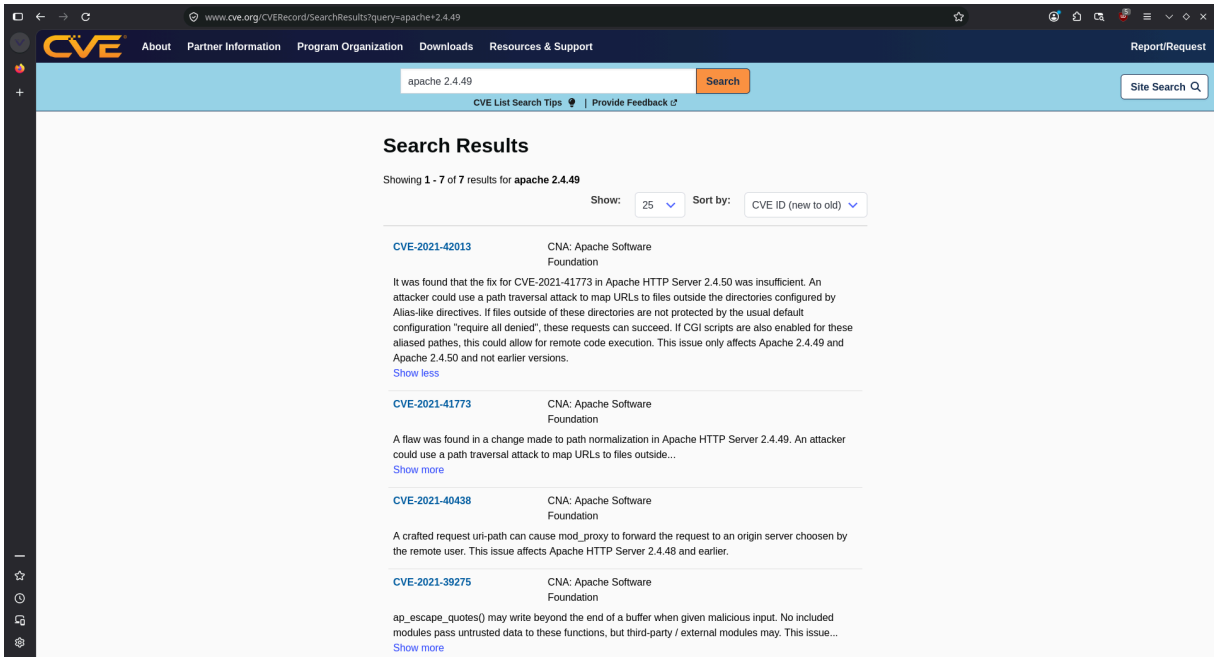


Figure 2: The result of a CVE search

What we have done on Figure 2 is search for known vulnerabilities in a database. There is a database for publicly known vulnerabilities called CVE which is short for common vulnerabilities and exposures. According to the result we found on Figure 2 we can do a path traversal attack which could also lead to remote code execution.

Normally we are not going to manually search for known CVEs on a website like we have seen at Figure 2. A similar result can be achieved by using the `searchsploit` command. `searchsploit` can give us known vulnerabilities of the specific Apache version. Look at Figure 3 to see the result of running the command `searchsploit apache 2.4.49`

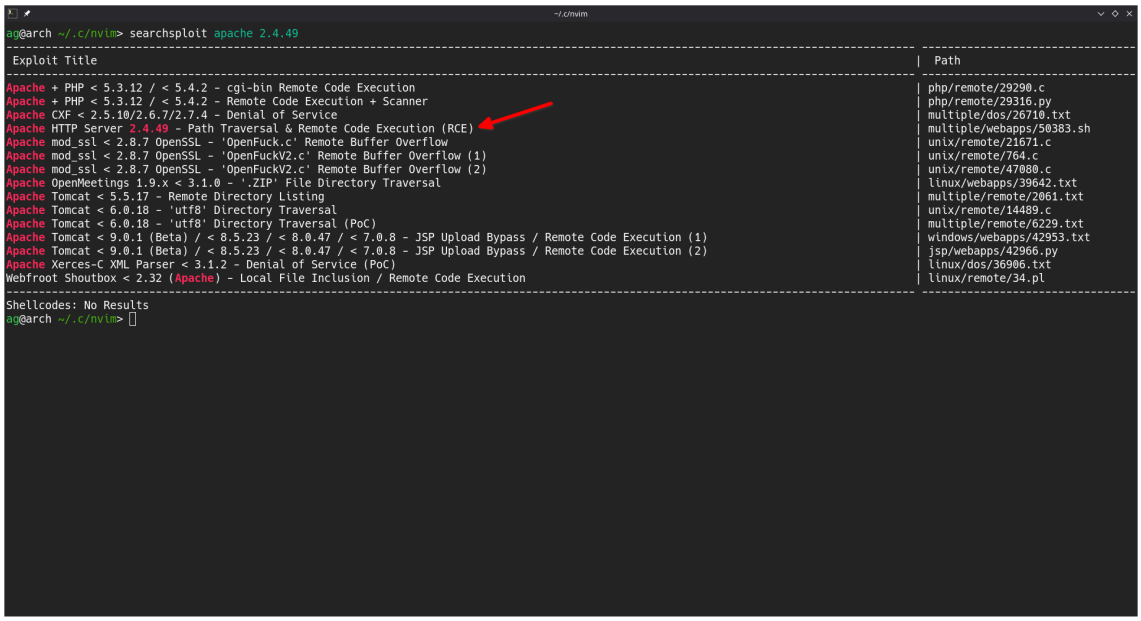


Figure 3: Searching CVEs with searchsploit

An even easier approach will be using a dedicated vulnerability scanning tools like `nikto`. nikto is used to find vulnerabilities in web applications.

Exploitation

After a vulnerability is found the next step is to exploit it. Vulnerability is a weakness on a system that could be taken advantage of while exploitation means using that weakness to access or cause damage to a system. In the next section we will see one of the most common tools to exploit a system which is metasploit.

Metasploit

Metasploit is a tool used to identify and exploit vulnerabilities in a system. Metasploit comes with a collection of ready made exploits that can used directly. `msfconsole` is the command we will run to get into metasploit's console.

In the metasploit console if we run `search apache 2.4.49` we will get a list of modules that can be used for exploitation (look at Figure 4). A module is a program used by metasploit to perform a task which could be exploitation, evasion (try to not be detected by antivirus) or payload execution (a code that runs after a successfully exploit) and others types. The output is showing us an exploit that could lead to RCE. To select that exploit we can run `use` followed by the exploits number which makes the command in this case be `use 0`. Figure 4 shows what this would look like.

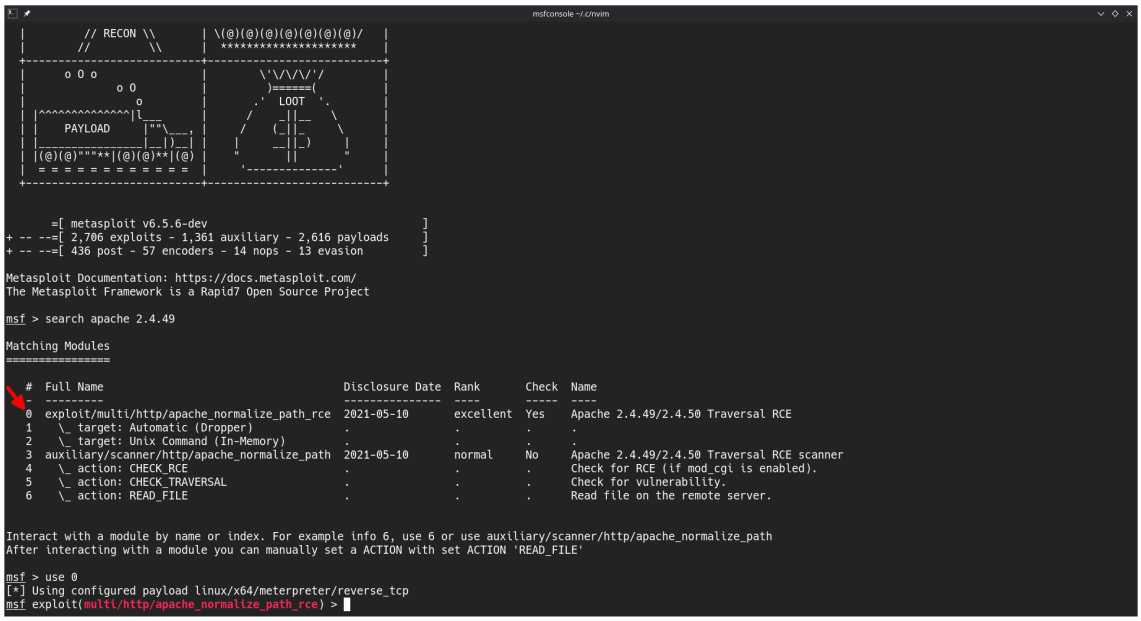


Figure 4: metasploit searching and using an exploit

Before running the selected payload we have to give additional information to metasploit such us the target device we want to compromise and our device so that the target will connect back to us. To fill in the target device run the command `use RHOST [target]`, `[target]` will be the IP address of the target machine. the R in `RHOST` stands for right. The command `use LHOST [target]` is used to provide our IP address the L stands for local. After filling in the required information if we run the `exploit` command inside the metasploit console at which point a payload will run on the target machine to give as a meterpreter access.

when exploiting an RCE vulnerability using metasploit, having a shell access gives us the ability to run arbitrary commands on our target's device. A meterpreter access can allow us to do things like taking a screenshot or use the attacked systems webcam on top of a shell access.

Extras

Although I mainly focused on penetration testing I also tried to look into cryptography. In this Extras section I will write some things I find very interesting in the field of cryptography. Before we go into specifics, cryptography is the study of techniques for secure communication. For a cryptographic system to be considered useful the techniques must work even if an adversary finds the message in transit and knows the encryption method that is used. The only thing that we have to keep secret is our key. One question we might have is, if we are trying to send information in secret and we need a key to do that how can we agree on the key in the first place before establishing a secure communication. The next section will try to answer that.

Diffie-Hellman Key Exchange

The Diffie-Hellman key exchange is a protocol to generate a symmetric cryptographic key in a secure manner. The algorithm uses modular arithmetic but for ease of illustration we will use colors as an analogy.

If two people want to generate the same colors (a color is analogous to a cryptographic key here) they can start with a single shared color and a secret color for each of them. Each person will mix their secret color with their public color and will send the resulting color to the other person. Lastly

they will mix the colors they received from each other with the same color to their secret color. This process will lead to generating similar colors because each person has mixed the same three colors (only the order of mixing is different). See Figure 5 for clarity.

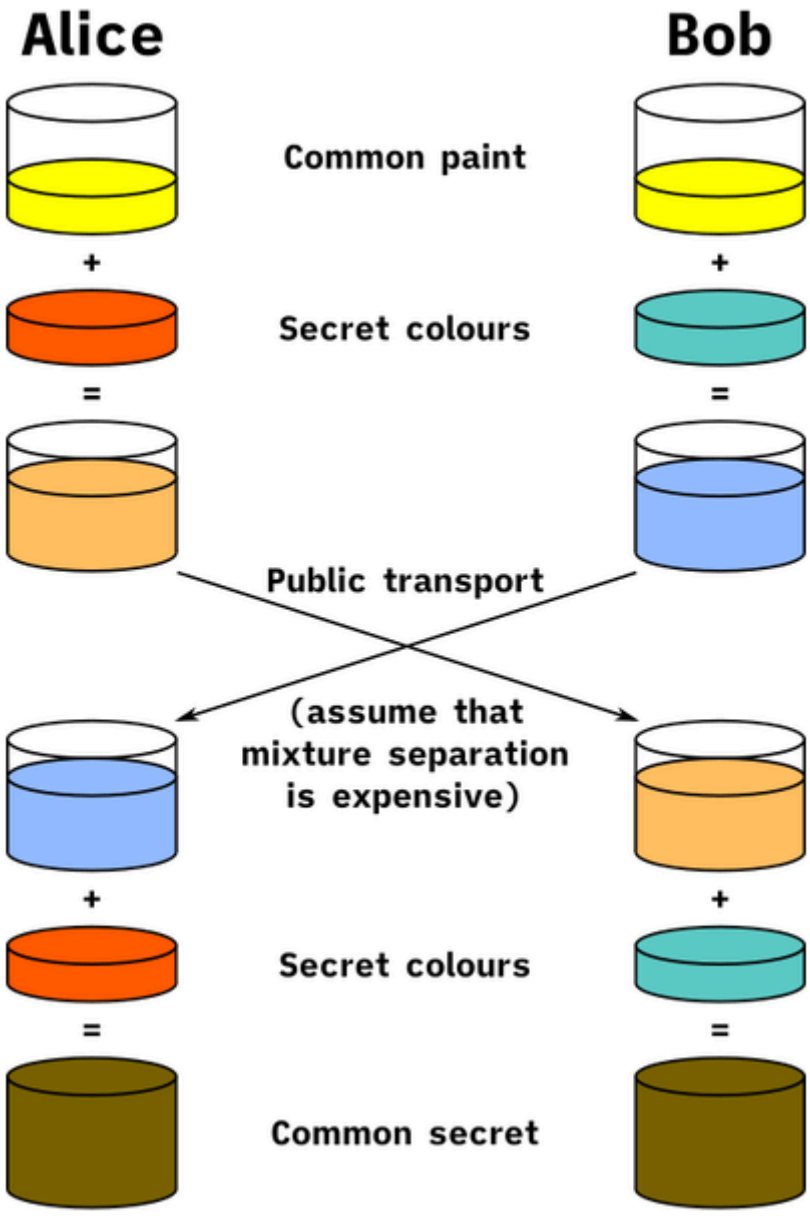


Figure 5: Diffie-Hellman key exchange using colors

Quantum Computers in Cryptography

The cryptography algorithms we use day to day are built on the assumption that some problems are hard to solve for computers. One hard problem for a computer to do is factoring a really large number into its prime components. Although factoring is a difficult task that takes a lot of time on a regular computer a quantum computer can do it quickly.

There is an algorithm called shor's algorithm that can be used to factor large number faster than any known algorithm that can run on a classical computer. This means most common encryption algorithms that rely on prime number can be broken (one of which is the Diffie-Hellman key exchange which we saw above).

At the time of me writing this largest number factored using shor's algorithm is 21 which is a very long way to the numbers we use for encryption. Although current quantum computers are not capable of compromising encryption algorithms like RSA information can be collected and stored now in the hopes of decrypting it latter.

Although quantum computers make many cryptography algorithms vulnerable there are algorithms based on problems that are thought to be hard for quantum computers to solve. These kinds of algorithms are called post-quantum algorithms.